

VindobonaPay GmbH — Statement of Applicability

ISO/IEC 27001:2022 Annex A (reference set, 93 controls) | Version 1.1 | Fictional company for educational purposes

Control ID	Control name	Applicable ?	Justification for inclusion / exclusion	Implementation status	Control owner	Related Risk ID	Evidence / Reference
5 — Organizational controls (37)							
A.5.1	Policies for information security	Yes	Core ISMS requirement; policies approved by management and reviewed yearly.	Implemented	CISO		Information Security Policy v1.0 (approved)
A.5.2	Information security roles and responsibilities	Yes	Roles must be clear in a small team where people wear several hats.	Implemented	CISO		Roles & responsibilities section, Information Security Policy
A.5.3	Segregation of duties	Yes	Payment operations require separation between initiation and approval.	Partially implemented	CISO		Segregation of duties matrix (draft)
A.5.4	Management responsibilities	Yes	Management must actively require security compliance from all staff.	Implemented	Management		Management review meeting minutes
A.5.5	Contact with authorities	Yes	Contact points with FMA and CERT.at are required for a payment provider.	Implemented	Compliance Officer		Authority contact list (FMA, CERT.at)
A.5.6	Contact with special interest groups	Yes	Membership in security communities keeps threat knowledge current.	Partially implemented	CISO		Security community membership records (partial)
A.5.7	Threat intelligence	Yes	Fintech is a common phishing/fraud target; threat feeds inform defenses.	Partially implemented	CISO		Ad-hoc threat monitoring notes
A.5.8	Information security in project management	Yes	Security requirements are part of every new product feature project.	Partially implemented	Head of Engineering		Project template (security section, draft)
A.5.9	Inventory of information and other associated assets	Yes	Asset inventory is the basis of the risk assessment.	Implemented	IT Manager		Asset inventory (Intune export + register)
A.5.10	Acceptable use of information and other associated assets	Yes	Staff handle payment data; acceptable use rules are mandatory.	Implemented	CISO		Acceptable Use Policy v1.0
A.5.11	Return of assets	Yes	Laptops and tokens must be returned on termination (offboarding checklist).	Implemented	HR Manager		Offboarding checklist
A.5.12	Classification of information	Yes	Payment data, PII and internal data need different protection levels.	Partially implemented	CISO		Data Classification Policy (draft)
A.5.13	Labelling of information	Yes	Labels in Microsoft 365 support the classification scheme.	Planned	IT Manager		Not available — remediation planned
A.5.14	Information transfer	Yes	Secure transfer rules for data shared with banks and partners.	Implemented	IT Manager		Information Transfer Procedure v1.0
A.5.15	Access control	Yes	Access to payment systems is restricted on need-to-know basis.	Implemented	IT Manager		Access Control Policy v1.0
A.5.16	Identity management	Yes	Single identity lifecycle in Entra ID (joiner/mover/leaver).	Implemented	IT Manager		Entra ID joiner-mover-leaver process
A.5.17	Authentication information	Yes	Password and MFA rules for all staff and service accounts.	Implemented	IT Manager		Password & MFA standard; Entra ID settings
A.5.18	Access rights	Yes	Access rights reviewed quarterly for payment and admin systems.	Partially implemented	IT Manager		Access review records (ad-hoc)
A.5.19	Information security in supplier relationships	Yes	Cloud and ICT suppliers process company data; security terms required.	Partially implemented	Compliance Officer		Supplier list with risk rating (partial)
A.5.20	Addressing information security within supplier agreements	Yes	Contracts include security, audit and breach notification clauses.	Partially implemented	Compliance Officer		Contract template with security clauses
A.5.21	Managing information security in the ICT supply chain	Yes	DORA requires managing risk from critical ICT providers.	Planned	Compliance Officer		Not available — remediation planned
A.5.22	Monitoring, review and change management of supplier services	Yes	Supplier performance and security reviewed at least yearly.	Planned	Compliance Officer		Not available — remediation planned
A.5.23	Information security for use of cloud services	Yes	Core infrastructure runs in the cloud; usage rules and exit plan needed.	Partially implemented	IT Manager		Cloud Services Policy v1.0
A.5.24	Information security incident management planning and preparation	Yes	Incident response plan required by ISO 27001, NIS2 and DORA.	Implemented	CISO		Incident Response Plan v1.1
A.5.25	Assessment and decision on information security events	Yes	Triage criteria decide what becomes an incident.	Implemented	CISO		Incident triage criteria (IRP annex)
A.5.26	Response to information security incidents	Yes	Documented response procedures for the incident team.	Implemented	CISO		Incident response runbooks
A.5.27	Learning from information security incidents	Yes	Post-incident reviews feed improvements into the ISMS.	Partially implemented	CISO		Post-incident notes (informal)
A.5.28	Collection of evidence	Yes	Evidence handling rules support possible legal or regulatory follow-up.	Planned	CISO		Not available — remediation planned
A.5.29	Information security during disruption	Yes	Security must not drop during outages of a payment service.	Partially implemented	CISO		Business Continuity Plan v1.0 (security annex draft)
A.5.30	ICT readiness for business continuity	Yes	Payment availability is critical; recovery objectives defined and tested.	Partially implemented	IT Manager		Recovery objectives (RTO/RPO) documented

Control ID	Control name	Applicable ?	Justification for inclusion / exclusion	Implementation status	Control owner	Related Risk ID	Evidence / Reference
A.5.31	Legal, statutory, regulatory and contractual requirements	Yes	PSD2, GDPR, NIS2 and DORA obligations tracked in a legal register.	Implemented	Compliance Officer		Legal & regulatory register
A.5.32	Intellectual property rights	Yes	Software licenses and third-party code use are controlled.	Implemented	Compliance Officer		Software license inventory
A.5.33	Protection of records	Yes	Transaction records kept per regulatory retention periods.	Implemented	Compliance Officer		Records retention schedule
A.5.34	Privacy and protection of PII	Yes	Customer PII processed under GDPR; DPO advises on processing.	Implemented	Compliance Officer		Privacy notice; GDPR Art. 30 processing register
A.5.35	Independent review of information security	Yes	Yearly internal audit of the ISMS by an independent reviewer.	Planned	Management		Not available — remediation planned
A.5.36	Compliance with policies, rules and standards for information security	Yes	Managers check that teams follow the security policies.	Partially implemented	CISO		Manager attestations (partial)
A.5.37	Documented operating procedures	Yes	Key IT and security procedures documented for continuity.	Partially implemented	IT Manager		IT runbook (in progress)
6 — People controls (8)							
A.6.1	Screening	Yes	Background checks proportionate to role, within Austrian labour law.	Implemented	HR Manager		HR screening procedure
A.6.2	Terms and conditions of employment	Yes	Employment contracts include security responsibilities.	Implemented	HR Manager		Employment contract template (security clauses)
A.6.3	Information security awareness, education and training	Yes	Yearly awareness training plus phishing simulations for all staff.	Implemented	CISO		Training records; phishing simulation reports
A.6.4	Disciplinary process	Yes	Formal process for security policy violations.	Implemented	HR Manager		Disciplinary process (HR handbook)
A.6.5	Responsibilities after termination or change of employment	Yes	Confidentiality duties survive employment end.	Implemented	HR Manager		Termination clauses in employment contracts
A.6.6	Confidentiality or non-disclosure agreements	Yes	NDAs signed by staff and external contractors.	Implemented	HR Manager		NDA templates (signed copies archived)
A.6.7	Remote working	Yes	Hybrid work is standard; remote work security rules apply.	Implemented	IT Manager		Remote Working Policy v1.0
A.6.8	Information security event reporting	Yes	Staff must report suspicious events through a simple channel.	Implemented	CISO		Event reporting channel (Teams); IRP
7 — Physical controls (14)							
A.7.1	Physical security perimeters	Yes	Office areas with payment operations are physically separated.	Implemented	Office Manager		Office floor plan with security zones
A.7.2	Physical entry	Yes	Badge access to office; visitors registered and escorted.	Implemented	Office Manager		Badge access logs; visitor register
A.7.3	Securing offices, rooms and facilities	Yes	Server room and archive locked with restricted access.	Implemented	Office Manager		Key and badge management records
A.7.4	Physical security monitoring	Yes	CCTV and alarm system at the Vienna office.	Partially implemented	Office Manager		CCTV and alarm system records
A.7.5	Protecting against physical and environmental threats	Yes	Fire protection and environmental risks addressed for office and server room.	Implemented	Office Manager		Fire protection inspection reports
A.7.6	Working in secure areas	Yes	Rules for work in the server room (no phones, supervised access).	Partially implemented	Office Manager		Server room access log
A.7.7	Clear desk and clear screen	Yes	Mandatory given customer PII on screens in a shared office.	Implemented	CISO		Clear Desk & Clear Screen Policy
A.7.8	Equipment siting and protection	Yes	Equipment placed to avoid unauthorized viewing and damage.	Implemented	IT Manager		Office layout guidelines
A.7.9	Security of assets off-premises	Yes	Laptops used remotely are encrypted and tracked.	Implemented	IT Manager		Disk encryption reports (Intune)
A.7.10	Storage media	Yes	Removable media restricted by policy and endpoint controls.	Implemented	IT Manager		Removable media restriction (Intune policy)
A.7.11	Supporting utilities	Yes	UPS for server room; cloud reduces on-prem dependency.	Implemented	Office Manager		UPS maintenance records
A.7.12	Cabling security	Yes	Office network cabling protected in a controlled space.	Implemented	IT Manager		Server room cabling documentation
A.7.13	Equipment maintenance	Yes	Maintenance by authorized personnel only, records kept.	Implemented	IT Manager		Equipment maintenance log
A.7.14	Secure disposal or re-use of equipment	Yes	Disks wiped or destroyed before disposal; certificates kept.	Implemented	IT Manager		Media disposal certificates
8 — Technological controls (34)							
A.8.1	User endpoint devices	Yes	Company laptops managed via MDM with encryption and hardening.	Implemented	IT Manager		Intune MDM configuration; hardening baseline
A.8.2	Privileged access rights	Yes	Admin accounts separate, MFA-protected and reviewed quarterly.	Implemented	IT Manager		Privileged account list; MFA enrollment report
A.8.3	Information access restriction	Yes	Access to payment data restricted by role.	Implemented	IT Manager		RBAC matrix (payment systems)
A.8.4	Access to source code	Yes	Source code in private repos with branch protection.	Implemented	Head of Engineering		GitHub branch protection settings

Control ID	Control name	Applicable ?	Justification for inclusion / exclusion	Implementation status	Control owner	Related Risk ID	Evidence / Reference
A.8.5	Secure authentication	Yes	MFA enforced for all users; conditional access policies.	Implemented	IT Manager		Entra ID Conditional Access policies
A.8.6	Capacity management	Yes	Cloud resources monitored and scaled to keep the service available.	Implemented	IT Manager		Azure Monitor capacity dashboards
A.8.7	Protection against malware	Yes	EDR on all endpoints; mail and web filtering.	Implemented	IT Manager		Microsoft Defender for Endpoint reports
A.8.8	Management of technical vulnerabilities	Yes	Monthly scans and patch SLAs based on severity.	Partially implemented	IT Manager		Monthly vulnerability scan reports
A.8.9	Configuration management	Yes	Hardening baselines for endpoints, servers and cloud services.	Partially implemented	IT Manager		Endpoint hardening baseline v1.0
A.8.10	Information deletion	Yes	Customer data deleted when retention ends (GDPR).	Partially implemented	IT Manager		Data retention schedule
A.8.11	Data masking	Yes	Payment data masked in non-production and in support views.	Planned	Head of Engineering		Not available — remediation planned
A.8.12	Data leakage prevention	Yes	DLP rules in Microsoft 365 for payment data and PII.	Planned	IT Manager		Not available — remediation planned
A.8.13	Information backup	Yes	Automated backups with periodic restore tests.	Implemented	IT Manager		Azure Backup configuration; restore test records
A.8.14	Redundancy of information processing facilities	Yes	Cloud redundancy across availability zones for the payment platform.	Implemented	IT Manager		Azure availability zones architecture
A.8.15	Logging	Yes	Central log collection for systems and payment application.	Partially implemented	IT Manager		Central logging configuration (partial)
A.8.16	Monitoring activities	Yes	Alerting on suspicious activity; DORA expects detection capability.	Partially implemented	CISO		Security alerting rules (initial set)
A.8.17	Clock synchronization	Yes	NTP on all systems so logs can be correlated.	Implemented	IT Manager		NTP configuration (Azure default)
A.8.18	Use of privileged utility programs	Yes	Admin tools restricted to authorized administrators.	Implemented	IT Manager		Admin tool access restrictions (Intune)
A.8.19	Installation of software on operational systems	Yes	Software installs restricted; application allow-listing on servers.	Partially implemented	IT Manager		Software installation restriction (Intune)
A.8.20	Networks security	Yes	Segmented networks, firewalls and secured Wi-Fi.	Implemented	IT Manager		Network diagram; firewall rules export
A.8.21	Security of network services	Yes	Security requirements defined for network service providers.	Partially implemented	IT Manager		Network services inventory
A.8.22	Segregation of networks	Yes	Production payment environment separated from office network.	Implemented	IT Manager		Network segmentation diagram
A.8.23	Web filtering	Yes	Web filtering blocks known malicious sites on endpoints.	Implemented	IT Manager		Web filtering configuration (Defender)
A.8.24	Use of cryptography	Yes	TLS everywhere, encryption at rest, documented key management.	Implemented	Head of Engineering		Cryptography standard; TLS configuration
A.8.25	Secure development life cycle	Yes	Security requirements, reviews and testing in the SDLC.	Partially implemented	Head of Engineering		SDLC guideline (draft)
A.8.26	Application security requirements	Yes	Security requirements defined for the payment application.	Partially implemented	Head of Engineering		Application security requirements (partial)
A.8.27	Secure system architecture and engineering principles	Yes	Secure-by-design principles documented and applied.	Partially implemented	Head of Engineering		Architecture diagrams with security notes
A.8.28	Secure coding	Yes	Secure coding guidelines and code review before merge.	Partially implemented	Head of Engineering		Code review checklist
A.8.29	Security testing in development and life cycle	Yes	SAST in the pipeline; yearly external penetration test.	Partially implemented	Head of Engineering		SAST reports; latest penetration test report
A.8.30	Outsourced development	No	All software is developed in-house by the VindobonaPay engineering team. No development is outsourced, so this control does not apply. This will be reviewed if outsourcing is ever introduced.	N/A	—	N/A	—
A.8.31	Separation of development, test and production environments	Yes	Separate dev/test/prod environments with controlled deployment.	Implemented	Head of Engineering		Environment separation (Azure subscriptions)
A.8.32	Change management	Yes	Changes to the payment platform follow an approval workflow.	Implemented	Head of Engineering		Change management workflow (Azure DevOps)
A.8.33	Test information	Yes	No real payment data in test; synthetic or masked data only.	Partially implemented	Head of Engineering		Test data guideline (draft)
A.8.34	Protection of information in test environments	Yes	Test environments access-controlled like production.	Partially implemented	Head of Engineering		Test environment access list

Legend:

Implemented

Partially implemented

Planned

Not applicable

Control ID	Control name	Applicable ?	Justification for inclusion / exclusion	Implementation status	Control owner	Related Risk ID	Evidence / Reference
------------	--------------	--------------	---	-----------------------	---------------	-----------------	----------------------

Note: the 'Related Risk ID' column will be populated after the risk assessment (Deliverable 02). SoA will then be updated to v2.0.

Remediation action / Target date
—
—
Formalize segregation of duties matrix for payment operations — Q4 2026
—
—
Join CERT.at community and document participation — Q3 2026
Subscribe to a structured threat intelligence feed — Q4 2026
Add security checklist to the project template — Q3 2026
—
—
—
Approve and roll out Data Classification Policy — Q4 2026
Configure Microsoft Purview sensitivity labels — Q1 2027
—
—
—
—
Introduce quarterly access reviews for all systems — Q4 2026
Complete security assessment of existing suppliers — Q4 2026
Update remaining supplier contracts with security clauses — Q1 2027
Define ICT supply chain risk procedure (DORA) — Q1 2027
Set up yearly supplier review process — Q1 2027
Document cloud exit strategy — Q4 2026
—
—
—
Introduce formal lessons-learned template — Q3 2026
Define evidence collection procedure — Q2 2027
Align security requirements with BCP scenarios — Q4 2026
Run first ICT continuity test — Q4 2026

Remediation action / Target date
—
—
—
—
Schedule first internal ISMS audit — Q1 2027
Introduce yearly policy compliance checks — Q4 2026
Complete documentation of key IT procedures — Q4 2026
—
—
—
—
—
—
—
—
—
—
—
Extend CCTV coverage to server room entrance — Q3 2026
—
Formalize secure area working rules — Q3 2026
—
—
—
—
—
—
—
—
—
—
—
—

Remediation action / Target date
—
—
—
Define patch SLAs by severity — Q3 2026
Complete hardening baselines for cloud services — Q4 2026
Automate retention-based deletion — Q1 2027
Implement data masking in test environments — Q1 2027
Configure DLP policies in Microsoft Purview — Q1 2027
—
—
Extend log collection to all payment components — Q4 2026
Define alerting use cases and on-call process — Q4 2026
—
—
Extend application allow-listing to all servers — Q4 2026
—
Document security requirements for network providers — Q3 2026
—
—
—
Formalize secure SDLC procedure — Q4 2026
Document security requirements per application module — Q4 2026
Document architecture security principles — Q4 2026
Adopt secure coding standard and developer training — Q4 2026
Add DAST to the CI pipeline — Q1 2027
—
—
—
Replace remaining realistic test data with synthetic data — Q3 2026
Align test environment access with production rules — Q3 2026

SoA Summary — VindobonaPay GmbH

Version 1.1 — all values calculated automatically (COUNTIF) from the SoA sheet.

Total Annex A controls	93
Applicable controls	92
Excluded controls	1

Implemented	55
Partially implemented	30
Planned	7

Implemented (% of applicable)	59.8
Open remediation actions	37

Excluded control: A.8.30 Outsourced development — all software is developed in-house.